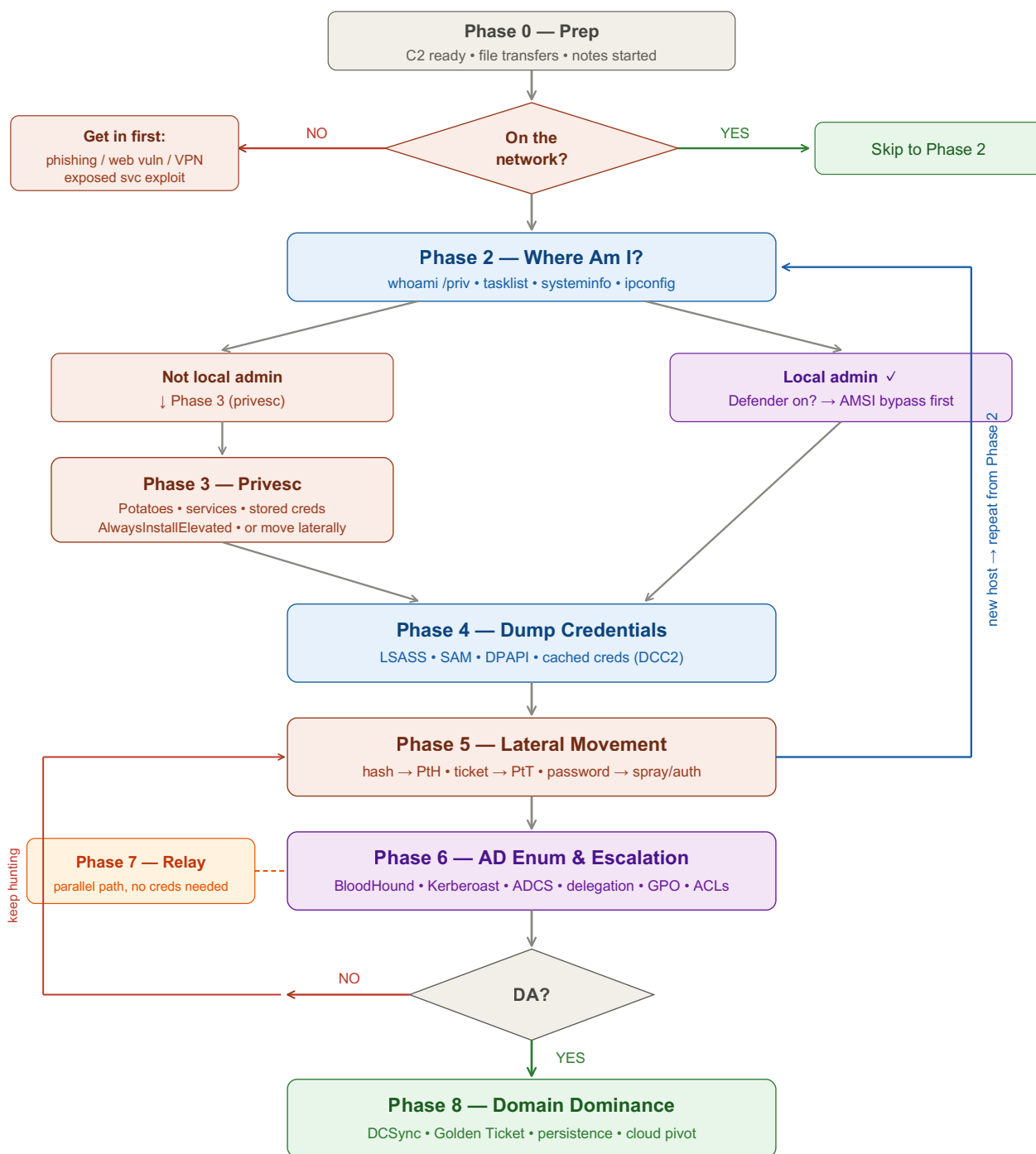


Windows AD Attack Chain — Decision Tree

A decision-tree walkthrough of a full AD engagement. Each tool name is a link to its dedicated cheatsheet for commands. Follow the flow, branch on decisions, click for details, come back and continue.



the chain is a loop: land → enum → dump → move → repeat until DA → dominate

0 Prep

- ☐ C2 ready? → [Sliver](#)
- ☐ File-transfer method? → [File Transfers](#)
- ☐ Note-taking started — log every cred, host, and path

1 Initial Access

Are you already on the internal network?

YES → skip to Phase 2

NO → get in:

Phishing? → [AitM Phishing](#) • [Evilginx](#)

Web app? → [SQLi](#) • [Command Injection](#) • [File Upload](#) • [LFI/RFI](#)

Exposed service? → exploit it, get a shell

Got a shell or callback? → Phase 2.

2 Where Am I?

Run on every new host. Full commands → [Windows Local Enum](#)

Am I local admin?

YES → skip to Phase 4 (dump creds)

NO → Phase 3 (privesc)

Is Defender / EDR running?

YES → bypass AMSI before any PS tooling → [AV / AMSI Bypass](#)

NO → proceed freely

Can I reach the DC and other subnets?

YES → continue

NO → set up a tunnel → [Pivoting & Tunneling](#)

3 Local Privesc

Only if NOT local admin. Full commands → [Windows Privesc](#)

SelmpersonatePrivilege?

YES → Potato attacks (GodPotato, PrintSpoofer)

Weak service permissions / unquoted paths?

YES → service-based privesc

Stored credentials? (cmdkey /list)

YES → runas /savecred

AlwaysInstallElevated?

YES → MSI privesc

Nothing works locally?

Try → lateral movement (Phase 5) to a host where you ARE admin

4 Dump Credentials

Is AMSI / Defender active?

YES → bypass first → [AV / AMSI Bypass](#)

NO → proceed

Dump targets:

LSASS memory → [LSASS Dumping](#)

nxc -M lsassy (remote, in-memory, stealthiest) • nxc -M nanodump (syscalls, AV evasion)

SAM + LSA in one shot → nxc --sam --lsa • secretsdump.py

LaZagne.exe all (browsers, wifi, vault, DPAPI, everything)

Autologon creds (registry Winlogon) • unattend.xml / sysprep.xml

Saved creds, DPAPI, browser passwords → [Credential Hunting](#)

Cached domain creds (DCC2) → [Hashcat](#) • [John](#)

What did you get?

NTLM hash → Phase 5 (pass-the-hash)

Kerberos TGT → Phase 5 (pass-the-ticket)

Cleartext password → Phase 5 (direct auth / spraying)

Nothing useful → Phase 4b (cred hunting) then Phase 6

4b Credential Hunting (no admin needed)

Before going to full AD enum, check these easy wins — they don't need local admin and are often overlooked.

Passwords in user descriptions?

→ nxc ldap <dc-ip> -M get-desc-users

GPP passwords (old Group Policy Preferences)?

→ nxc smb <dc-ip> -M gpp_password

LAPS passwords readable?

→ nxc ldap <dc-ip> --laps

gMSA passwords readable?

→ nxc ldap <dc-ip> --gmsa • gMSADumper.py

Creds in shares (scripts, configs, KeePass DBs)?

→ nxc --spider-shares • Snaffler.exe -s -o snaffler.log

Got something?

YES → Phase 5 (lateral movement)

NO → Phase 6 (AD enum for escalation paths)

5 Lateral Movement

Have an NTLM hash?

→ [Pass-the-Hash](#)

Have a Kerberos ticket?

→ [Pass-the-Ticket](#)

Have a cleartext password?

→ nxc smb/winrm/rdp directly

→ [Password Spraying](#) across the domain

Where to move next?

Hosts where your creds have local admin (nxc --shares)

High-value targets: DC, file servers, SCCM, ADCS, DB

Hosts with logged-in privileged users (BloodHound sessions)

Different subnet? → [Pivoting & Tunneling](#)

Every new host → go back to Phase 2. Land → Enum → Dump → Move → Repeat.

6 AD Enumeration & Escalation Paths

Is AMSI active? (SharpHound/PowerView will get caught)

YES → bypass first → [AV / AMSI Bypass](#)

Map the domain:

[BloodHound](#) • [LDAP Enumeration](#) • [Windows AD Enum](#)

Escalation paths:

Kerberoastable SPN on a privileged account?

→ [Kerberoasting](#)

AS-REP Roastable account (no preauth)?

→ [AS-REP Roasting](#)

Misconfigured ADCS template (ESC1–ESC8)?

→ [ADCS ESC Attacks](#)

Delegation abuse (unconstrained / constrained / RBCD)?

→ [Delegation Abuse](#)

Writable GPO linked to high-priv OU?

→ [GPO Abuse](#)

Can write msDS-KeyCredentialLink?

→ [Shadow Credentials](#)

SCCM/MECM misconfig?

→ [SCCM/MECM Attacks](#)

ACL abuse paths (GenericAll, WriteDACL, ForceChangePassword)?

→ BloodHound shows these — act on the path it gives you

Nothing yet?

→ password spray with known patterns

→ relay attacks (Phase 7)

→ hunt creds in shares, scripts, GPP, description fields

7 Relay & Coercion Attacks

No creds needed — just network position. Run in parallel with other phases.

Is SMB signing disabled?

YES → poison + relay:

[LLMNR Poisoning / Responder](#)

[SMB Relay](#) • [NTLM Relay](#)

NO → relay to LDAP / HTTP / ADCS instead

Can you coerce auth from a DC / high-value server?

→ [Authentication Coercion](#) (PetitPotam, PrinterBug, DFSCoerce)

Is ADCS web enrollment exposed?

→ coerce + relay → [ADCS Relay](#)

IPv6 unclaimed on the network?

→ [mitm6](#) + LDAP relay

8 Domain Dominance

You have DA or equivalent. Finish the job.

DCSync — dump every hash (secretsdump.py with DA creds)

Forge tickets → [Golden / Silver Tickets](#)

Persistence → [Windows Persistence](#)

Domain is hybrid / cloud-connected?

→ [Azure Enumeration](#) • [Entra ID Attacks](#)

When to Bypass AMSI — Quick Reference

NEED bypass (Defender on + running these on target):

Mimikatz / Invoke-Mimikatz

Rubeus

PowerView / SharpView

SharpHound (PowerShell collector)

Any offensive PS script

DON'T need bypass:

Python tools from attack box (impacket, nxc)

C# via execute-assembly in C2

LOLBins (certutil, rundll32)

Anything running from your Linux box

→ [AV / AMSI Bypass](#)

Key idea: AD pentesting is a loop — land on a host, enumerate, dump credentials, move laterally, repeat. Check for AMSI/Defender before running any PowerShell tooling on target. Use BloodHound to find the shortest path to Domain Admin. Once there, DCSync + Golden Ticket = game over.